Nhill Server 3.0 — Server component

Français : ../fr/serveur.md

The Nhill server (`nhill-server`) is the only access point to the data: Nhill Business, Nhill POS and Nhill Console talk to it over HTTPS (API `v1`); no application connects to the database. It is written in C++17, runs on Linux and relies on PostgreSQL 15 or later.

Topic	Document
Chosen production set-up (Hostinger VPS in France)	vps-deployment-hostinger.md
Manual installation, upgrade, troubleshooting	installation-guide.md § 4 to 6
Every key of `/etc/nhill/server.env`	configuration-guide.md § 1
Database (roles, migrations, backups)	database.md
API endpoints (generated from the code)	api-reference.md
Security and known risks	security.md, 03-security-audit.md

1. What the server does

- Authenticates users (Argon2id passwords, 15-minute access tokens, rotating refresh tokens) and console administrators (password and TOTP code).
- Enforces rights: the role's permissions, the features and limits of the business's plan, the subscription state (full access, read-only, no access). The applications hide what is not allowed, but the server decides.
- Computes and issues documents (numbering, taxes, rounding, A4 and receipt PDFs), keeps stock through movements, records payments, till sessions and the activity log.
- Sets the business of each transaction (`app.establishment_id`): the business-management tables only expose that business's rows (forced row-level security).
- Runs the background jobs (§ 4) and sends the automatic e-mails.

2. Installing

Case	Procedure
Production on an Ubuntu 24.04 VPS (Hostinger, France)	`deploy/vps/provision.sh`: local PostgreSQL, Caddy (TLS), firewall, encrypted backups, monitoring; automatic acceptance with 12 checks — vps-deployment-hostinger.md
Another Linux server, existing PostgreSQL or Supabase database	package `nhill-server_3.0.0-1_amd64.deb` (Ubuntu 24.04 or Debian 13), then installation from Nhill Console or on the command line — installation-guide.md § 4
Development machine	`scripts/dev/dev-stack.sh start` (throwaway PostgreSQL, never in production) — developer-guide.md

Installed without a database, the server starts in **setup mode**: it only exposes `/health`, `/api/v1/meta` and `/api/v1/setup/*`, and prints in its log a setup token valid 60 minutes (new token at each restart). Nhill Console uses this token to create the roles, apply the migrations and save the configuration; the server then restarts in normal operation.

3. Commands

`nhill-server [--config FILE] COMMAND` (the package uses `/etc/nhill/server.env`).

Command	Effect
`serve`	starts the API; without a configured database, starts in setup mode; refuses to start if a migration is pending or if the database was migrated by a newer version
`setup --host … --port … --user … [--admin-email … --admin-name …]`	command-line installation (password of the database administrator read from standard input or `NH_SETUP_DB_PASSWORD`, never stored)
`migrate`	applies pending migrations with the owner role (`NH_MIGRATION_DATABASE_URL`)
`check`	checks the configuration, database access, that no migration is pending, and syncs the country profiles
`run-jobs`	runs the background jobs once (exit code 1 if a code rotation fails)
`admin-bootstrap EMAIL NAME`	creates the first console administrator, or gives them a new token while their first access is not complete (token valid 30 minutes)
`version`	prints the server and API versions

The configuration file must belong to `nhill` with mode 600: the server refuses to start if other accounts can read it.

4. Background jobs

Every `NH_JOBS_INTERVAL_SECONDS` seconds (300 by default; `0` disables):

1. rotation of business codes that reached their due date;
2. subscription cycle: an already-paid downgrade takes effect at the end of the period, reminders before the due date (the plan's schedule, else the platform's), grace period when the due date passed without confirmed payment, then fallback plan or read-only at the end of the grace period, expiry of unpaid payment requests;
3. sending of pending e-mails (a dedicated thread sends recovery codes at once);
4. clean-ups: expired join tickets and anti-abuse counters, reset requests finished 30 days ago, e-mails sent or abandoned 30 days ago, sessions ended 90 days ago.

Permanent erasure of a business is never automatic: it is done from Nhill Console, 90 days after access ends (nhill-console.md § 4).

5. Operation

Need	Means
Status	`curl -s https://api.<domain>/health` → `{"database":true,"status":"ok"}`; `503` when the database does not answer
Log	`journalctl -u nhill-server` (one JSON line per event)
Monitoring	on the VPS: `nhill-healthcheck.timer` every 5 minutes (services, PostgreSQL, local and HTTPS API, certificate, local ports, firewall, disk, last backup) with an alert on failure

Need	Means
Backups	`nhill-backup.timer` every night at 02:30, files encrypted with `age` — database.md § 5
Update, rollback	`nhill-update`: package and checksum check, encrypted backup, local database copy, installation, waiting for `/health`, automatic rollback on failure (`nhill-rollback`) — vps-deployment-hostinger.md § 10
Reinstall on a new machine	vps-deployment-hostinger.md § 11

6. Security

- The server listens on `127.0.0.1:8080`; only Caddy (TLS, HSTS) is exposed on 80/443. `NH_TRUST_PROXY=1` only behind that proxy.
- `NH_SECRET_KEY` encrypts the business codes, the administrators' TOTP secrets and the payment providers' secrets: keep a copy off the server, with the backups' private key.
- Database roles are separate: owner (migrations), application (subject to row-level security, no definition rights), backup (read-only).
- Dependencies: libraries of the Ubuntu 24.04 / Debian 13 repositories (cpp-httplib, libpqxx, libsodium, libharu, libcurl, zlib). Known risks and pending decisions: 03-security-audit.md (R1: cpp-httplib 0.14.3 of the Ubuntu repositories).

7. Useful error codes

Code	Meaning
`401 invalid_token`	token missing, expired or revoked: the application renews it or asks to sign in again
`401 invalid_credentials`	wrong e-mail or password (same answer in every case)
`403 permission_denied`	the role does not have the permission
`403 feature_not_included`	the business's plan does not include the feature
`402 subscription_suspended`	read-only (subscription expired or suspended): viewing and export remain possible
`409 plan_limit_reached`, `user_limit_reached`, `plan_register_limit`	plan limit reached

The applications compare their version with `min_client_version` (`GET /api/v1/meta`) and ask for an update when they are too old. Full list and checks per route: api-reference.md.